Cheatsheet AZ-305 — 14 · Security: Defender, Sentinel, Key Vault, B2C and encryption

1. Microsoft Defender for Cloud

Element	What it is	Signal
CSPM (Foundational, free)	Secure Score, recommendations, inventory, basic compliance	"improve security posture", "secure score"
Defender CSPM (paid)	Attack path analysis, cloud security explorer, governance rules	"attack paths"
Defender for Servers (Plan 1/2)	Threat detection on VMs (Azure, Arc), **JIT VM access**, vulnerability assessment, file integrity (P2)	"temporary RDP/SSH", "threat detection on VMs"
Defender for SQL	Vulnerability assessment + Advanced Threat Protection (injection, anomalies)	"detect SQL injection"
Defender for Storage	Malware scanning, suspicious activity	"scan uploaded blobs for malware"
Defender for Containers	AKS runtime, image scanning in ACR	"scan container images"
Defender for Key Vault / App Service / DNS / Resource Manager	Per-service threat detection	
Regulatory compliance	Dashboard per standard (ISO 27001, PCI DSS, NIST, CIS…); based on Azure Policy initiatives	"assess compliance against PCI DSS"
Workflow automation	Logic App on alert/recommendation	"automatic response"
Continuous export	Alerts/recommendations to Log Analytics / Event Hubs (SIEM)	"send alerts to third-party SIEM" → Event Hubs
Azure Arc	Extends Defender to on-prem / other-cloud servers	"hybrid servers"

- Defender is **not** a secret store nor a firewall: it detects and recommends.
- **JIT VM access** ≠ PIM: JIT opens **ports** temporarily; PIM activates **roles**.

2. Microsoft Sentinel

Element	What it is
What it is	Native **SIEM + SOAR**, on top of a Log Analytics workspace
Data connectors	Entra ID, Microsoft 365, Defender, Azure Activity, firewalls, AWS, Syslog/CEF
Analytics rules	Detections (scheduled KQL, ML, fusion) → incidents
Workbooks	Visualization
Hunting	Proactive search with KQL
Playbooks	Response automation with **Logic Apps** (SOAR)
UEBA	User and entity behavior analytics
Signal	"SIEM", "correlate security events across sources", "automate incident response", "security orchestration"

- Sentinel vs Defender: **Defender** = posture and workload protection; **Sentinel** = correlation, investigation and response at organizational scale. They complement each other (Defender is a Sentinel connector).
- Sentinel vs Log Analytics: Sentinel **adds** detection, incidents and automation on top of the workspace.

3. Advanced Key Vault

Feature	Detail
Soft delete	Mandatory (enabled); retention 7-90 days; recover deleted vault/objects
Purge protection	Prevents permanent deletion during the retention period, **even by administrators**; irreversible once enabled; required for CMK on Storage/SQL/Disk Encryption
RBAC vs access policies	RBAC recommended (Key Vault Administrator / Secrets User / Crypto User…); access policies legacy
Networking	Firewall, service endpoints, **Private Endpoint**; "Allow trusted Microsoft services"
SKU	Standard (software) · **Premium** (HSM-backed, FIPS 140-2 Level 2) · **Managed HSM** (Level 3, single-tenant, own HSM pool) · **Dedicated HSM** (Thales, full control, no PaaS integration)
Rotation	Automatic key rotation by policy; auto-renewable certificates with integrated CA (DigiCert, GlobalSign)
Logging	Diagnostic settings → Log Analytics to audit key usage
BYOK / HYOK	Import your own keys (BYOK); HYOK = key never in the cloud (only Managed HSM / AIP scenarios)
Replication	Automatic to the paired region; read-only during failover
References from App Service / Functions	@Microsoft.KeyVault(SecretUri=...) in app settings with managed identity

- "audit key use + you manage keys + always encrypted at rest" (VM disks) → **Azure Disk Encryption** with Key Vault (or SSE with CMK).
- "FIPS 140-2 Level 2" → Premium; "Level 3" → Managed HSM.

4. Microsoft Entra External ID / B2C

Concept	Detail
Entra B2C	Separate tenant for **customers/consumers**: sign-up, social login (Google, Facebook), **OIDC/SAML federation with third-party IdPs**, user flows and custom policies (Identity Experience Framework)
Entra B2B	Invite **partners** as guests into the corporate tenant; collaboration with Microsoft 365/apps
External ID	Current umbrella name (B2B + external tenants for customers)
B2C issues JWTs	APIs validate them (via APIM validate-jwt with the B2C policy's metadata endpoint)
Signal	"customers", "social login", "third-party OIDC identity provider", "consumer-facing app" → B2C; "partner employees access our SharePoint" → B2B; "no guest accounts" → not B2B either: APIM with JWT validation from the external IdP

5. Encryption and data protection: full map

State / need	Technology	Detail
At rest, Storage	SSE (PMK / **CMK** in Key Vault)	Always on; infrastructure encryption for a double layer
At rest, VM disks	**Azure Disk Encryption** (BitLocker/DM-Crypt, keys in your Key Vault, auditable) · SSE with CMK · Encryption at host · Confidential disk	ADE = "you manage the keys"
At rest, SQL	**TDE** (service-managed or CMK); Policy DINE to enforce	Files and backups
Sensitive columns hidden from DBAs	**Always Encrypted** (deterministic allows equality/join; randomized does not)	"group and join on encrypted columns" → deterministic
Mask by role	**Dynamic Data Masking**	Does not encrypt
In transit	TLS 1.2+, HTTPS only, IPsec, MACsec	"secure transfer required"
In use	**Confidential Computing** (Confidential VMs DCasv5/ECasv5, SGX, enclaves, confidential containers)	"code being processed", "protect from cloud operator"
Application keys	Key Vault secrets + managed identity	Never in code
TLS certificates	Key Vault certificates + App Service / App Gateway integration	Auto-renewal
Data in Microsoft 365 / files	Microsoft Purview Information Protection (sensitivity labels, DLP)	Outside AZ-305 unless mentioned
Regulatory immutability	Immutable Storage (time-based Locked / legal hold)	WORM
Anti-ransomware backups	Soft delete + Resource Guard (MUA)	

6. Compliance and security governance

Need	Solution
Assess against a standard (ISO, PCI, NIST, CIS)	Defender for Cloud **Regulatory compliance** (Policy initiatives)
Enforce secure configurations	Azure Policy (Deny/DINE): HTTPS only, minimum TLS, no public IP, encryption
Trust Center / Microsoft audits	**Service Trust Portal** (SOC, ISO reports)
Data residency	Choose region/geo; Policy "allowed locations"
Separation of duties	RBAC + PIM + Resource Guard + Purge protection
Audit of who did what	Activity Log (control plane) + diagnostic logs (data plane) + Entra audit logs
Long retention of security logs (7 years)	Log Analytics archive / export to immutable Storage
Secrets in pipelines	Key Vault + service connections with workload identity federation

7. Decision tree

```
What is asked?
├─ Posture, secure score, recommendations, JIT ..... Defender for Cloud
├─ Threats on VMs / SQL / Storage / containers ..... Defender for <service>
├─ SIEM, multi-source correlation, automated response .... Sentinel (+ Logic Apps playbooks)
├─ Compliance against a standard ..... Defender Regulatory compliance
├─ Secrets / keys / certificates ..... Key Vault (Premium if HSM L2, Managed HSM if L3)
├─ Nobody can delete the vault or the keys ..... Purge protection + soft delete
├─ Customer identity / social / external IdP ..... Entra B2C
├─ Partners with an account in my tenant ..... Entra B2B
├─ Disk encryption with my keys and auditing ..... Azure Disk Encryption
├─ Data in use ..... Confidential Computing
└─ Column not even the DBA can see ..... Always Encrypted
```

8. Signals → answer

Wording	Answer
"temporary access to management ports"	JIT VM access (Defender for Servers)
"detect SQL injection attempts"	Defender for SQL
"correlate security events from Azure, M365 and on-prem firewalls"	Sentinel

Wording	Answer
"automated response to incidents"	Sentinel playbooks (Logic Apps)
"assess against PCI DSS"	Regulatory compliance
"prevent permanent deletion of keys even by admins"	Purge protection
"FIPS 140-2 Level 2 / Level 3"	Key Vault Premium / Managed HSM
"customers sign in with Google"	Entra B2C
"join tables on encrypted columns"	Always Encrypted deterministic
"encrypt while processing"	Confidential Computing
"send Defender alerts to Splunk"	Continuous export → Event Hubs
"alerts when unauthorized login attempts on VMs"	Defender for Servers / Log Analytics security events + alert

9. Mistakes to avoid

1. Defender as a SIEM → Sentinel.
2. Sentinel as a posture tool → Defender.
3. B2B when the wording says "customers" or "no guest accounts".
4. Key Vault Standard for an HSM requirement.
5. Dynamic Data Masking as encryption.
6. Always Encrypted randomized when joins are required.